

## Capstone 2 – AITEE Care Medical Center Phishing Incident Analysis

(Based strictly on the provided case file telemetry. No invented evidence, malware strain, attacker identity, exfiltration, EHR access, or ransomware confirmation.)

### SECTION 3 — PHISHING & SOCIAL ENGINEERING ANALYSIS

#### Task 1 — Phishing Indicator Analysis (at least 5)

| Phishing Indicator                           | Analytical Explanation (Why It's Suspicious)                                                                                                                                                 |
|----------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1.Sender domain mismatch                     | Email claims to be from "IT Support" but uses it-support@aitee-care-security.com. Legitimate organizational domain is aitee-care.org. Evidence suggests domain spoofing / look-alike domain. |
| 2.Urgency language + time pressure           | Subject "ACTION REQUIRED" and body text "verify their account within 30 minutes. Failure... may result in temporary account suspension" creates artificial deadline.                         |
| 3.Generic greeting + broad targeting         | Addressed to "Administrative Staff" rather than a named individual, typical of bulk spear-phishing                                                                                           |
| 4.Call-to-action link only                   | Sole interactive element is a hyperlinked "VERIFY ACCOUNT" button with no legitimate verification process described.                                                                         |
| 5.Unexpected MFA push after credential entry | User received an unsolicited MFA prompt immediately after submitting credentials on the linked page; user later confirmed the 10:05 AM login was not intentional                             |

#### Task 2 — Social Engineering Psychological Analysis(at least 2)

| Technique                             | Psychological Mechanism & Operational Impact |
|---------------------------------------|----------------------------------------------|
| 1.Technique 1: Urgency / Fear of loss | Threat of account suspension within 30       |

|                                   |                                                                                                                                                                    |
|-----------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                   | minutes exploits fear of operational disruption. This pressured the employee to click the link and enter credentials without verification.                         |
| 2. Technique 2: Authority / Trust | Email is framed as originating from the internal "IT Security Team." Users are conditioned to comply with IT directives, lowering scrutiny of the domain and link. |

## SECTION 4 — ATTACK TIMELINE & KILL CHAIN MODEL

**Task 3 — Incident Timeline Reconstruction** (already partially completed in worksheet; completed version)

| Time     | Event Description                                                | Analyst Notes / Significance      |
|----------|------------------------------------------------------------------|-----------------------------------|
| 09:05 AM | Phishing email received by Admin staff<br>Initial delivery phase | Initial delivery phase            |
| 09:12 AM | Employee clicks link & submits credentials                       | Credential harvesting             |
| 09:14 AM | Unexpected MFA push prompt approved                              | MFA fatigue / bypass achieved     |
| 10:05 AM | Unusual account login detected by IT                             | Unauthorized session active       |
| 10:20 AM | Shared departmental files become inaccessible                    | Impact / possible execution phase |

### Timeline Reporting Analysis Question

The incident should ideally have been reported by the user at 09:14 AM (or immediately after the unexpected MFA prompt).

Reason: At that moment the user recognized an unrecognized MFA push. Early reporting would have allowed IT to revoke the session before the 10:05 AM anomalous login and subsequent shared-folder impact.

#### **Task 4 — Visual Attack Chain Model**

(Use the exact sequence provided in the worksheet; include the diagram in your portfolio.)

1. Phishing Email Received
- ↓
2. Fake Login Page Navigation
- ↓
3. Credential Submission (Username/Password)
- ↓
4. Unexpected MFA Push Approval
- ↓
5. Unauthorized Account Access (10:05 AM Alert)
- ↓
6. Suspicious Shared File Activity / Inaccessibility

### **SECTION 5 — INCIDENT CLASSIFICATION & SEVERITY ASSESSMENT**

#### **Task 5 — Incident Classification & Analysis**

| <b>Investigation Question</b> | <b>Analyst Fact-Based Assessment</b>                                                                                                                                                                                                                           |
|-------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Primary Initial Vector?       | Phishing (Spear-phishing credential harvesting)                                                                                                                                                                                                                |
| Primary Target Asset?         | User domain credentials and account access rights                                                                                                                                                                                                              |
| Authentication Breach?        | MFA prompt misuse / unauthorized approval                                                                                                                                                                                                                      |
| Downstream Impact?            | Unusual login and shared network file manipulation                                                                                                                                                                                                             |
| Is Ransomware Confirmed?      | NO. Why must you NOT confirm ransomware yet? Only inaccessible files, unusual naming conventions, and locked files have been observed. No confirmed encryption ransom note, malware signature, or encryption event has been provided. Further investigation is |

|  |           |
|--|-----------|
|  | required. |
|--|-----------|

## Task 6 — Severity Determination

YOUR SELECTION:HIGH

Justification (2–3 analytical reasons):

1. Confirmed unauthorized access to an administrative employee account after credential submission and MFA approval.
2. Immediate operational impact on shared departmental network folders used by multiple employees (inaccessible / locked files).
3. Healthcare environment elevates risk because administrative accounts often have elevated rights and the organization relies on shared folders for workflow.

(Not yet Critical because ransomware encryption and EHR patient-record impact remain unconfirmed.)

## SECTION 6 — FIRST RESPONSE ACTION PLAN

### Task 7 — Prioritized First Response (Top 5 Actions)

| Recommended Response Action                                       | Operational Reason & Purpose                                                          |
|-------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| 1.Notify Security/IT Team                                         | Ensures coordinated response and escalation of the 10:05 AM alert.                    |
| 2.Secure Account / Revoke Active Sessions                         | Immediately terminates the unauthorized session observed at 10:05 AM.                 |
| 3.Reset Credentials                                               | Invalidates harvested username/password combination.                                  |
| 4.Isolate Affected Systems / Determine Affected Files             | Limits further shared-folder impact and preserves evidence of locked/unusual files.   |
| 5.Preserve Evidence / Investigate Login & Malicious File Activity | Captures logs, MFA approval records, and file-system changes for later investigation. |

## SECTION 7 — INCIDENT TICKET DOCUMENTATION

### Task 8 — Security Incident Ticket (ID: AITEE-W4-002)

- Date / Time: 09 Sep 2026 / 10:05 AM (or current submission time)
- Incident Type: Phishing / Credential Compromise leading to unauthorized access
- Severity Level: HIGH
- Current Status: Under Investigation

Initial Findings (3–5 concise bullet points of verified facts):

- Administrative employee received phishing email at 09:05 AM from look-alike domain.
- Credentials submitted at 09:12 AM; unexpected MFA push approved at 09:14 AM.
- Anomalous location login detected at 10:05 AM; user confirmed login was not intentional.
- Shared departmental network folders became inaccessible / exhibited unusual naming at 10:20 AM.

Immediate Containment Actions Recommended:

Revoke active sessions, reset credentials, isolate affected shared folders, preserve logs and file metadata.

Outstanding Investigation Questions (at least 3):

1. What is the exact source IP / geolocation of the 10:05 AM login?
2. Which specific shared-folder files were modified or locked, and is any encryption present?
3. Did the compromised account access any EHR or other sensitive systems after 10:05 AM?

## SECTION 8 — OPERATIONAL PLAYBOOK & STRATEGIC CONTROLS

### Task 9 — User Outreach Communication (80–120 words) (Blame-free, professional)

Subject: Security Notice – Account Activity Follow-up

Dear [Employee Name],

Thank you for confirming that the 10:05 AM login was not intentional. Your quick response helps us protect the organization.

Please change your password immediately using the official password-reset portal and avoid approving any unexpected MFA prompts. Do not click links in unsolicited “account verification” emails. Going forward, report any suspicious messages or prompts directly to the IT Security team.

We appreciate your cooperation. Additional security awareness guidance will be shared shortly.

Best regards,  
IT Security Team  
AITEE Care Medical Center

Task 10 — Simplified Incident Response Playbook Flow  
(Use the table already provided in the worksheet; it is complete.)

Task 11 — Recommended Security Controls (3 Pillars)

| Control Pillar | Recommended Control Measure                                                                                                   | How It Reduces Risk                                                 |
|----------------|-------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------|
| People         | Mandatory phishing simulation + MFA-fatigue awareness training                                                                | Improves recognition of urgency tactics and unexpected MFA prompts. |
| Process        | Require out-of-band verification (phone/Teams) for any “account verification” request                                         | Breaks the authority + urgency social-engineering chain             |
| Technology     | Enforce number-matching MFA + conditional access (block anomalous locations) + enhanced email authentication (DMARC/SPF/DKIM) | Prevents MFA push abuse and spoofed-domain delivery                 |

Task 12 — Final Executive Summary (150–200 words)

At approximately 09:05 AM an administrative employee received a spear-phishing email from a look-alike domain impersonating IT Support. The message used urgency and authority to induce credential submission at 09:12 AM and approval of an unexpected MFA push at 09:14 AM. Telemetry later detected an anomalous-location login at 10:05 AM, which the user confirmed was not intentional. By 10:20 AM multiple employees reported inaccessible shared network folders exhibiting unusual naming conventions.

The evidence suggests credential harvesting followed by unauthorized account access and subsequent shared-folder impact. Ransomware encryption, data exfiltration, and EHR access remain unconfirmed and require further investigation. Primary organizational priorities are

immediate session revocation, credential reset, isolation of affected shares, and preservation of forensic artifacts. Lessons learned include the need for stronger MFA controls, improved email authentication, and reinforced user reporting of unexpected authentication prompts.